Sicherheitsbericht

Lokales Testziel

Automatisierte technische Sicherheitsprüfung im angegebenen Umfang. Kein vollständiger Penetrationstest, keine ISO-Zertifizierung und kein Nachweis der vollständigen rechtlichen oder datenschutzrechtlichen Konformität.

1. Management-Zusammenfassung

Im Prüfmodus A – Schonender Basischeck wurden 17 Feststellungen dokumentiert: 2 Sicherheitslücke(n), 14 Konfigurationshinweis(e) und 1 Verdachtsfall/-fälle, die noch verifiziert werden müssen. 2 Feststellung(en) sind als hoch oder kritisch eingestuft und sollten priorisiert behandelt werden. Von 21 in diesem Modus implementierten Prüfpunkten wurden 21 tatsächlich geprüft. Nicht geprüfte Bereiche sind in Abschnitt 6 aufgeführt.

Kritisch	0
Hoch	2
Mittel	6
Niedrig	9
Information	0

Kennzahlen werden getrennt ausgewiesen und nicht zu einem Gesamtwert verrechnet. Prüfabdeckung = Anzahl der im gewählten Modus implementierten Prüfpunkte mit Status «geprüft» / Anzahl aller im Modus implementierten Prüfpunkte. Befundzahlen zählen dedupliziert (gleicher Fingerprint = eine Feststellung).

2. Ziel, Umfang und Prüfzeitpunkt

Website	Lokales Testziel
Basis-URL	https://127.0.0.1:8443/
Umgebung	Staging
Verantwortlich	E2E A
Prüfmodus	A – Schonender Basischeck
Start / Ende	13.10.2026, 11:01 / 13.10.2026, 11:02
Freigegebene Hosts	127.0.0.1
Erlaubte Pfade	/
Ausgeschlossene Pfade	–
Limits	max. 1500 Anfragen, 10/s, 8 min, Tiefe 5

3. Freigegebene und tatsächlich ausgeführte Prüfmethoden

• Native Prüfungen: TLS, HTTP->HTTPS, Sicherheits-Header, Cookies, Mixed Content, /.git/HEAD, security.txt
• ZAP Spider (ohne Formularversand) + passive Regeln

Netzwerkschutz: 12 Verbindungen erlaubt, 0 ausserhalb des Scopes blockiert.

4. Feststellungen nach Priorität

4.1 TLS-Zertifikat nicht vertrauenswürdig

Art	Sicherheitslücke
Schweregrad / Vertrauen	Hoch / Bestätigt
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-TLS-01
Kontext	anonym
Referenzen	ASVS 12.2.2, WSTG WSTG-CRYP-01, OWASP-TOP10 A04:2025, CWE CWE-295, ISO27002 8.24 (unverifiziert)

Das Zertifikat konnte nicht gegen vertrauenswürdige Zertifizierungsstellen validiert werden (DEPTH_ZERO_SELF_SIGNED_CERT). Browser zeigen eine Warnung; Nutzende gewöhnen sich an das Wegklicken.

Massnahme:

Ein öffentlich vertrauenswürdiges Zertifikat (z. B. Let's Encrypt) mit vollständiger Zertifikatskette und passendem Hostnamen einsetzen.

Nachweis (bereinigt):

```
Protokoll: TLSv1.3
Cipher: TLS_AES_256_GCM_SHA384
Subjekt: CN=127.0.0.1
Aussteller: CN=127.0.0.1
Gültig bis: Nov 12 08:45:33 2026 GMT
SAN: IP Address:127.0.0.1
Vertrauenswürdig: nein (DEPTH_ZERO_SELF_SIGNED_CERT)
```

4.2 Git-Repository-Daten öffentlich abrufbar

Art	Sicherheitslücke
Schweregrad / Vertrauen	Hoch / Bestätigt
Status	Offen
Betroffen	https://127.0.0.1:8443/.git/HEAD
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-CFG-01
Kontext	anonym
Referenzen	ASVS 13.4.1, WSTG WSTG-CONF-04, CWE CWE-527

Das .git-Verzeichnis ist über den Webserver abrufbar. Damit lassen sich oft der vollständige Quellcode und eingecheckte Geheimnisse rekonstruieren.

Massnahme:

Zugriff auf /.git/ im Webserver sperren und das Verzeichnis nicht mit ausliefern; eingecheckte Secrets rotieren.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/.git/HEAD -> Status 200
ref: refs/heads/main
```

4.3 Cookie «sessionid» ohne Secure-Attribut

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Mittel / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-CK-01
Kontext	anonym
Referenzen	ASVS 3.3.1, WSTG WSTG-SESS-02, CWE CWE-614

Das Cookie kann auch über unverschlüsselte HTTP-Verbindungen übertragen werden.

Massnahme:

Attribut «Secure» setzen; für Sitzungscookies zusätzlich das Präfix «__Host-» verwenden.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/
Set-Cookie: sessionid=[ENTFERNT]; Path=/
```

4.4 Cookie «sessionid» ohne HttpOnly-Attribut

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Mittel / Mittel
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-CK-02

Kontext	anonym
Referenzen	ASVS 3.3.4, WSTG WSTG-SESS-02, CWE CWE-1004

Das Cookie wirkt wie ein Sitzungs- oder Authentifizierungscookie und ist für JavaScript lesbar. Bei einer XSS-Lücke könnte es ausgelesen werden.

Massnahme:

Für alle Cookies, die nicht von Skripten gelesen werden müssen, «HttpOnly» setzen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/
Set-Cookie: sessionid=[ENTFERNT]; Path=/
```

4.5 Aktive gemischte Inhalte (HTTP-Skripte/Frames auf HTTPS-Seite)

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Mittel / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-MC-01
Kontext	anonym
Referenzen	WSTG WSTG-CRYP-03, CWE CWE-319

Die HTTPS-Seite bindet Skripte, Stylesheets oder Frames über HTTP ein. Moderne Browser blockieren diese meist; wo nicht, können sie manipuliert werden.

Massnahme:

Alle eingebundenen Ressourcen über HTTPS laden; zusätzlich CSP «upgrade-insecure-requests» erwägen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/
<script> http://127.0.0.1:8081/app.js
<img> http://127.0.0.1:8081/logo.png
```

4.6 CORS spiegelt beliebige Origins

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Mittel / Mittel
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-HDR-07
Kontext	anonym
Referenzen	ASVS 3.4.2, WSTG WSTG-CLNT-07, CWE CWE-942

Die Anwendung erlaubt Cross-Origin-Zugriffe von beliebigen Origins. In Kombination mit Credentials können fremde Websites Daten im Namen angemeldeter Nutzender lesen.

Massnahme:

Access-Control-Allow-Origin nur für eine feste Allowlist vertrauenswürdiger Origins setzen; Credentials nur, wenn zwingend nötig.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/ mit Origin: https://webaudit-cors-probe.invalid
Access-Control-Allow-Origin: https://webaudit-cors-probe.invalid
Access-Control-Allow-Credentials: true
```

4.7 Keine Weiterleitung von HTTP auf HTTPS

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Mittel / Bestätigt
Status	Offen
Betroffen	http://127.0.0.1:8081/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-HTTP-01
Kontext	anonym

Referenzen	ASVS 12.2.1, WSTG WSTG-CRYP-03, OWASP-TOP10 A04:2025, CWE CWE-319

Die Website ist über unverschlüsseltes HTTP erreichbar, ohne auf HTTPS weiterzuleiten.

Massnahme:

Alle HTTP-Anfragen mit Status 301/308 auf die HTTPS-Variante derselben URL weiterleiten und HSTS setzen.

Nachweis (bereinigt):

```
GET http://127.0.0.1:8081/ -> Status 200
```

4.8 Formular ohne Anti-CSRF-Token

Art	Verdacht – Verifikation erforderlich
Schweregrad / Vertrauen	Mittel / Niedrig
Status	Offen
Betroffen	https://127.0.0.1:8443/contact
Weitere Fundstellen	–
Werkzeug / Regel	OWASP ZAP 2.17.0 / zap:10202
Kontext	anonym
Referenzen	CWE CWE-352

Ein HTML-Formular enthält kein erkennbares Anti-CSRF-Token. Ob die Anwendung CSRF auf andere Weise verhindert (z. B. SameSite-Cookies, Origin-Prüfung), wurde nicht geprüft.

Massnahme:

Für zustandsändernde Formulare ein Anti-CSRF-Token oder eine gleichwertige Massnahme (SameSite=Strict/Lax, Origin-Prüfung) einsetzen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/contact
Nachweis: <form method="post" action="/contact">
```

4.9 TLS-Zertifikat läuft in 29 Tagen ab

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Niedrig / Bestätigt
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-TLS-03
Kontext	anonym
Referenzen	WSTG WSTG-CRYP-01, CWE CWE-298

Ein abgelaufenes Zertifikat führt zu Browserwarnungen und Verbindungsabbrüchen.

Massnahme:

Zertifikat erneuern und automatische Erneuerung einrichten (z. B. ACME).

Nachweis (bereinigt):

```
Protokoll: TLSv1.3
Cipher: TLS_AES_256_GCM_SHA384
Subjekt: CN=127.0.0.1
Aussteller: CN=127.0.0.1
Gültig bis: Nov 12 08:45:33 2026 GMT
SAN: IP Address:127.0.0.1
Vertrauenswürdig: nein (DEPTH_ZERO_SELF_SIGNED_CERT)
```

4.10 Strict-Transport-Security-Header fehlt

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Niedrig / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	9 (z. B. https://127.0.0.1:8443/sitemap.xml)
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-HDR-01
Kontext	anonym
Referenzen	ASVS 3.4.1, WSTG WSTG-CONF-07, OWASP-TOP10 A02:2025, CWE CWE-319

Die Antwort enthält keinen HSTS-Header. Browser können dadurch bei späteren Besuchen zunächst eine unverschlüsselte Verbindung aufbauen.

Massnahme:

Header «Strict-Transport-Security: max-age=31536000; includeSubDomains» auf allen HTTPS-Antworten setzen (includeSubDomains nur, wenn alle Subdomains HTTPS unterstützen).

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/ -> Status 200
strict-transport-security: (nicht gesetzt)
```

4.11 Content-Security-Policy-Header fehlt

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Niedrig / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	9 (z. B. https://127.0.0.1:8443/sitemap.xml)
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-HDR-02
Kontext	anonym
Referenzen	ASVS 3.4.3, OWASP-TOP10 A02:2025, CWE CWE-693

Es ist keine Content Security Policy gesetzt. Eine CSP begrenzt die Auswirkungen von Cross-Site-Scripting und eingeschleusten Inhalten.

Massnahme:

Eine restriktive CSP einführen, mindestens: default-src 'self'; object-src 'none'; base-uri 'none'; frame-ancestors 'none'. Zunächst im Report-Only-Modus testen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/ -> Status 200
content-security-policy: (nicht gesetzt)
content-security-policy-report-only: (nicht gesetzt)
```

4.12 Header X-Content-Type-Options fehlt

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Niedrig / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	8 (z. B. https://127.0.0.1:8443/products/1)
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-HDR-03
Kontext	anonym
Referenzen	ASVS 3.4.4, CWE CWE-693

Ohne «X-Content-Type-Options: nosniff» können Browser den Inhaltstyp erraten (MIME-Sniffing) und Inhalte unerwartet als Skript oder HTML interpretieren.

Massnahme:

Header «X-Content-Type-Options: nosniff» auf allen Antworten setzen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/ -> Status 200
x-content-type-options: (nicht gesetzt)
content-type: text/html; charset=utf-8
```

4.13 Kein Schutz vor Clickjacking

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Niedrig / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	8 (z. B. https://127.0.0.1:8443/products/1)
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-HDR-05
Kontext	anonym
Referenzen	ASVS 3.4.6, WSTG WSTG-CLNT-09, CWE CWE-1021

Die Seite kann in fremde Seiten eingebettet werden. Angreifende können Nutzende so zu ungewollten Klicks verleiten.

Massnahme:

CSP-Direktive «frame-ancestors 'none'» (oder 'self') setzen; X-Frame-Options kann zusätzlich für alte Browser bleiben.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/ -> Status 200
content-security-policy: (nicht gesetzt)
x-frame-options: (nicht gesetzt)
```

4.14 Header verraten Software oder Versionen

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Niedrig / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	11 (z. B. https://127.0.0.1:8443/sitemap.xml)
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-HDR-06
Kontext	anonym
Referenzen	ASVS 13.4.6, WSTG WSTG-INFO-02, CWE CWE-200

Server- oder X-Powered-By-Header nennen eingesetzte Software und teilweise deren Version. Das erleichtert gezielte Angriffe auf bekannte Schwachstellen.

Massnahme:

X-Powered-By entfernen und den Server-Header auf eine generische Angabe ohne Version reduzieren.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/ -> Status 200
server: Apache/2.4.1 (Unix)
x-powered-by: PHP/5.6.40
```

4.15 Cookie «sessionid» ohne wirksames SameSite-Attribut

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Niedrig / Mittel
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-CK-03
Kontext	anonym
Referenzen	ASVS 3.3.2, WSTG WSTG-SESS-02, CWE CWE-1275

Ohne explizites SameSite-Attribut hängt das Verhalten vom Browser ab.

Massnahme:

SameSite=Lax (Standard) oder Strict setzen; None nur mit Secure und nur wenn seitenübergreifende Nutzung nötig ist.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/
Set-Cookie: sessionid=[ENTFERNT]; Path=/
```

4.16 Cookie «prefs» ohne Secure-Attribut

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Niedrig / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-CK-01
Kontext	anonym
Referenzen	ASVS 3.3.1, WSTG WSTG-SESS-02, CWE CWE-614

Das Cookie kann auch über unverschlüsselte HTTP-Verbindungen übertragen werden.

Massnahme:

Attribut «Secure» setzen; für Sitzungscookies zusätzlich das Präfix «__Host-» verwenden.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/
Set-Cookie: prefs=[ENTFERNT]; Path=/
```

4.17 Cookie «prefs» ohne wirksames SameSite-Attribut

Art	Konfigurationshinweis
Schweregrad / Vertrauen	Niedrig / Mittel
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-CK-03
Kontext	anonym
Referenzen	ASVS 3.3.2, WSTG WSTG-SESS-02, CWE CWE-1275

Ohne explizites SameSite-Attribut hängt das Verhalten vom Browser ab.

Massnahme:

SameSite=Lax (Standard) oder Strict setzen; None nur mit Secure und nur wenn seitenübergreifende Nutzung nötig ist.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/
Set-Cookie: prefs=[ENTFERNT]; Path=/
```

4.18 Referrer-Policy nicht gesetzt

Art	Information
Schweregrad / Vertrauen	Information / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-HDR-04
Kontext	anonym
Referenzen	ASVS 3.4.5, CWE CWE-200

Es ist keine Referrer-Policy gesetzt. Aktuelle Browser verwenden standardmässig «strict-origin-when-cross-origin»; ältere Browser können vollständige URLs übermitteln.

Massnahme:

Header «Referrer-Policy: strict-origin-when-cross-origin» (oder strenger) setzen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/ -> Status 200
referrer-policy: (nicht gesetzt)
```

4.19 Cookie «prefs» ohne HttpOnly-Attribut

Art	Information
Schweregrad / Vertrauen	Information / Niedrig
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-CK-02
Kontext	anonym
Referenzen	ASVS 3.3.4, WSTG WSTG-SESS-02, CWE CWE-1004

Das Cookie ist für JavaScript lesbar. Ob das beabsichtigt ist, kann nicht automatisch beurteilt werden.

Massnahme:

Für alle Cookies, die nicht von Skripten gelesen werden müssen, «HttpOnly» setzen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/
Set-Cookie: prefs=[ENTFERNT]; Path=/
```

4.20 Cross-Origin-Opener-Policy nicht gesetzt

Art	Information
Schweregrad / Vertrauen	Information / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-HDR-08
Kontext	anonym
Referenzen	ASVS 3.4.8

Ohne COOP teilt die Seite ihren Browsing-Kontext mit fremden Fenstern, die sie öffnen. Gemäss ASVS ist dies eine Level-3-Anforderung.

Massnahme:

«Cross-Origin-Opener-Policy: same-origin» setzen, sofern keine Popups mit fremden Seiten kommunizieren müssen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/ -> Status 200
cross-origin-opener-policy: (nicht gesetzt)
```

4.21 Sitzungscookie «sessionid» ohne __Host-/__Secure-Präfix

Art	Information
Schweregrad / Vertrauen	Information / Mittel
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-CK-04
Kontext	anonym
Referenzen	ASVS 3.3.3

Cookie-Präfixe verhindern, dass Subdomains oder unverschlüsselte Verbindungen das Cookie überschreiben.

Massnahme:

Sitzungscookies als «__Host-<name>» mit Secure, Path=/ und ohne Domain-Attribut setzen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/
Set-Cookie: sessionid=[ENTFERNT]; Path=/
```

4.22 Keine security.txt vorhanden

Art	Information
Schweregrad / Vertrauen	Information / Hoch
Status	Offen
Betroffen	https://127.0.0.1:8443/.well-known/security.txt
Weitere Fundstellen	–
Werkzeug / Regel	WebAudit Native Checks 0.1.0 / WA-CFG-02
Kontext	anonym
Referenzen	–

Eine security.txt (RFC 9116) teilt Sicherheitsforschenden mit, wie Schwachstellen gemeldet werden können.

Massnahme:

Datei /.well-known/security.txt mit mindestens «Contact:» und «Expires:» bereitstellen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/.well-known/security.txt -> Status 404
```

4.23 Cache-Steuerung für möglicherweise sensible Inhalte

Art	Information
Schweregrad / Vertrauen	Information / Niedrig
Status	Offen
Betroffen	https://127.0.0.1:8443/about

Weitere Fundstellen	–
Werkzeug / Regel	OWASP ZAP 2.17.0 / zap:10015
Kontext	anonym
Referenzen	CWE CWE-525

Antworten enthalten keine oder eine zu offene Cache-Steuerung. Sensible Inhalte könnten in gemeinsam genutzten Caches oder im Browser verbleiben.

Massnahme:

Für Seiten mit personenbezogenen oder sensiblen Inhalten «Cache-Control: no-store» setzen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/about
Parameter: cache-control
```

4.24 Cache-Steuerung für möglicherweise sensible Inhalte

Art	Information
Schweregrad / Vertrauen	Information / Niedrig
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	OWASP ZAP 2.17.0 / zap:10015
Kontext	anonym
Referenzen	CWE CWE-525

Antworten enthalten keine oder eine zu offene Cache-Steuerung. Sensible Inhalte könnten in gemeinsam genutzten Caches oder im Browser verbleiben.

Massnahme:

Für Seiten mit personenbezogenen oder sensiblen Inhalten «Cache-Control: no-store» setzen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/
Parameter: cache-control
```

4.25 Cache-Steuerung für möglicherweise sensible Inhalte

Art	Information
Schweregrad / Vertrauen	Information / Niedrig
Status	Offen
Betroffen	https://127.0.0.1:8443/products/1
Weitere Fundstellen	5 (z. B. https://127.0.0.1:8443/products/2)
Werkzeug / Regel	OWASP ZAP 2.17.0 / zap:10015
Kontext	anonym
Referenzen	CWE CWE-525

Antworten enthalten keine oder eine zu offene Cache-Steuerung. Sensible Inhalte könnten in gemeinsam genutzten Caches oder im Browser verbleiben.

Massnahme:

Für Seiten mit personenbezogenen oder sensiblen Inhalten «Cache-Control: no-store» setzen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/products/1
Parameter: cache-control
```

4.26 Cache-Steuerung für möglicherweise sensible Inhalte

Art	Information
Schweregrad / Vertrauen	Information / Niedrig
Status	Offen
Betroffen	https://127.0.0.1:8443/contact
Weitere Fundstellen	–
Werkzeug / Regel	OWASP ZAP 2.17.0 / zap:10015
Kontext	anonym

Referenzen	CWE CWE-525

Antworten enthalten keine oder eine zu offene Cache-Steuerung. Sensible Inhalte könnten in gemeinsam genutzten Caches oder im Browser verbleiben.

Massnahme:

Für Seiten mit personenbezogenen oder sensiblen Inhalten «Cache-Control: no-store» setzen.

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/contact
Parameter: cache-control
```

4.27 Möglicherweise sensible Informationen in Kommentaren

Art	Information
Schweregrad / Vertrauen	Information / Mittel
Status	Offen
Betroffen	https://127.0.0.1:8443/
Weitere Fundstellen	–
Werkzeug / Regel	OWASP ZAP 2.17.0 / zap:10027
Kontext	anonym
Referenzen	CWE CWE-615

Im HTML- oder JavaScript-Quelltext wurden Kommentare mit Schlüsselwörtern gefunden, die auf interne Informationen hindeuten können.

Massnahme:

Kommentare prüfen und interne Hinweise vor der Auslieferung entfernen (z. B. per Build-Minifizierung).

Nachweis (bereinigt):

```
GET https://127.0.0.1:8443/
Nachweis: <!-- TODO: admin password im
```

5. Vergleich mit vorherigem Scan

Kein vorheriger abgeschlossener Scan desselben Modus vorhanden.

6. Prüfabdeckung und nicht geprüfte Bereiche

WA-TLS-01 – HTTPS erreichbar und Zertifikat vertrauenswürdig: Geprüft

WA-TLS-02 – Ausgehandelte TLS-Version: Geprüft (Akzeptanz veralteter Versionen nicht geprüft)

WA-TLS-03 – Restlaufzeit des Zertifikats: Geprüft

WA-HTTP-01 – Weiterleitung von HTTP auf HTTPS: Geprüft

WA-HDR-01 – HTTP Strict Transport Security (HSTS): Geprüft

WA-HDR-02 – Content Security Policy: Geprüft

WA-HDR-03 – X-Content-Type-Options: nosniff: Geprüft

WA-HDR-04 – Referrer-Policy: Geprüft

WA-HDR-05 – Schutz vor Clickjacking (frame-ancestors): Geprüft

WA-HDR-06 – Versionsangaben in Server-Headern: Geprüft

WA-HDR-07 – CORS: Wildcard mit Credentials: Geprüft

WA-HDR-08 – Cross-Origin-Opener-Policy: Geprüft

WA-CK-01 – Cookie-Attribut Secure: Geprüft

WA-CK-02 – Cookie-Attribut HttpOnly: Geprüft

WA-CK-03 – Cookie-Attribut SameSite: Geprüft

WA-CK-04 – Cookie-Präfix __Host-/__Secure-: Geprüft

WA-MC-01 – Gemischte Inhalte (Mixed Content): Geprüft

WA-CFG-01 – Öffentlich erreichbare Versionsverwaltungsdaten (.git): Geprüft

WA-CFG-02 – security.txt vorhanden: Geprüft

WA-CRAWL-01 – Erfassung öffentlich erreichbarer Seiten im Scope: Geprüft (Ohne JavaScript-Ausführung; begrenzt durch Request- und Zeitlimit)

WA-ZAP-PASSIVE – Passive ZAP-Regeln auf gecrawlten Antworten: Geprüft

Nicht Bestandteil dieses Prüfmodus bzw. nicht automatisiert:

• WA-AUTH-01 – Testsitzung gültig und von anonymem Zugriff unterscheidbar (anderer Modus)

• WA-AUTH-02 – Logout beendet die Sitzung serverseitig (anderer Modus)
• WA-AUTH-03 – Geschützte Bereiche je Testrolle erfassen (anderer Modus)
• WA-ACT-01 – Aktive ZAP-Prüfung mit Profil «webaudit-safe» (anderer Modus)
• WA-REPO-01 – Secrets im Repository (gitleaks) (anderer Modus)
• WA-REPO-02 – Bekannte Schwachstellen in Abhängigkeiten (osv-scanner) (anderer Modus)
• WA-REPO-03 – Statische Codeanalyse (semgrep) (anderer Modus)
• WA-MAN-01 – Zugriffskontrolle und Rollenmodell (nicht implementiert / manuell)
• WA-MAN-02 – Business-Logik (nicht implementiert / manuell)
• WA-MAN-03 – Authentifizierungsverfahren (Passwortregeln, MFA, Sperrlogik) (nicht implementiert / manuell)
• WA-MAN-04 – Cross-Site Request Forgery (nicht implementiert / manuell)
• WA-MAN-05 – Protokollierung und Alarmierung (nicht implementiert / manuell)
• WA-MAN-06 – Datenschutzrechtliche Konformität (nicht implementiert / manuell)

7. Verwendete Werkzeuge und Referenzversionen

OWASP ZAP	2.17.0
WebAudit Native Checks	0.1.0

Prüfkatalog-Version 2026.10.0

• OWASP Application Security Verification Standard 5.0.0 (übernommen 2026-10-13; CC BY-SA 4.0 (Creative Commons Attribution-ShareAlike 4.0))
• OWASP Web Security Testing Guide 4.2 (übernommen 2026-10-13; CC BY-SA 4.0)
• OWASP Top 10 2025 (übernommen 2026-10-13; CC BY-SA 4.0)
• Common Weakness Enumeration 4.20 (übernommen 2026-10-13; CWE Terms of Use (MITRE, frei nutzbar mit Quellenangabe))
• Common Vulnerability Scoring System 4.0 (übernommen 2026-10-13; FIRST CVSS Terms of Use)
• ISO/IEC 27002:2022 (Zuordnung) 2022 (übernommen 2026-10-13; Urheberrechtlich geschützt (ISO). Keine Normtexte übernommen.)

Automatisierte technische Sicherheitsprüfung im angegebenen Umfang. Kein vollständiger Penetrationstest, keine ISO-Zertifizierung und kein Nachweis der vollständigen rechtlichen oder datenschutzrechtlichen Konformität.